PROBLEM STATEMENT 03 · SECURITY / SANDBOX ONLY

Build an Agent That Pentests a Target on Its Own

Penetration testing requires more than running a fixed sequence of commands. Security testers interpret results, identify potential weaknesses, and continuously decide what to investigate next. An autonomous security agent must demonstrate this decision-making process while operating strictly within an authorized environment.

The challenge focuses on building an agent capable of exploring an unfamiliar target, interpreting tool results, and working toward a defined security objective without human intervention.

GOAL

Build an autonomous penetration-testing agent that operates inside an isolated, organizer-provided laboratory. During judging, the agent receives an unfamiliar target, a scope file, and a specific objective; the lab has no route to the public internet or real-world systems.

MANDATORY REQUIREMENTS

- **Environment exploration:** Identify authorized hosts, ports, services, and versions using real security tools rather than assumptions.
- **Objective completion:** Combine multiple actions to achieve the assigned lab objective, including movement between lab machines when explicitly permitted.
- **Reporting:** Produce an actionable security report documenting findings, severity, supporting evidence, and recommended remediation.
- **Autonomous reasoning:** Interpret tool output, select subsequent actions, and recover from unsuccessful attempts.
- **Strict scope enforcement:** Never interact with systems outside the supplied scope. Any out-of-scope activity results in automatic failure.

EXPECTED OUTCOME

An autonomous agent that can complete a defined security objective within an isolated lab, demonstrate its decision-making process, maintain strict scope compliance, and produce a useful security assessment.

OPTIONAL IMPLEMENTATION GUIDANCE

Participants may explore single-machine scenarios, multi-step lab objectives, or an agent paired with an automated report generator. Testing is permitted only inside explicitly authorized, isolated environments; real-world targets and unauthorized systems are strictly excluded.